1. Network Protocols, Ports & Industry Standards

Networking

Core Protocol Acronyms

Verified Acronym Definitions:

- **IIS:** Internet Information Services (Microsoft Web Server).
- **URI:** Uniform Resource Identifier (Superset identifying resources by name or location).
- **RIP:** Routing Information Protocol (Distance-vector routing, UDP 520, max 15 hops).
- **EIGRP:** Enhanced Interior Gateway Routing Protocol (Cisco proprietary, IP Protocol 88).
- **OSPF:** Open Shortest Path First (Link-state routing protocol, IP Protocol 89).
- **NNTP:** Network News Transfer Protocol (TCP 119 / NNTPS TCP 563).
- **SSH:** Secure Shell (Encrypted remote admin, TCP 22).
- **TKIP:** Temporal Key Integrity Protocol (WPA wrapper for WEP using RC4).
- **PGP:** Pretty Good Privacy (Asymmetric signing and file encryption standard).
- **AJAX:** Asynchronous JavaScript and XML (Client-side asynchronous data retrieval).

Port Numbers, Ranges & IPsec Architecture

UDP/TCP Port Range: 0 to 65535 | Port 69: TFTP | Port 200: IBM SRC

IPsec Ports: UDP 500 (IKE / ISAKMP Phase 1), UDP 4500 (NAT-Traversal), IP Protocol 50 (ESP - Encryption + Integrity), IP Protocol 51 (AH - Integrity only).

Listing Directories on a Remote TFTP Server

Correct Answer: TFTP has no capability or command to list directories.

RFC 1350 supports only Read Request (RRQ), Write Request (WRQ), DATA, ACK, and ERROR. Exact filenames must be targeted directly.

MAC Address Bytes for Network Interface Card (NIC)

Correct Answer: The last 3 bytes (24 bits).

Bytes 1–3 represent the vendor OUI (Organizationally Unique Identifier). Bytes 4–6 represent the vendor-assigned NIC identifier.

Operating System Fingerprinting via Default TTL

TTL 128 = Windows | TTL 64 = Linux/macOS | TTL 255 = Solaris / Cisco IOS

Inspected in raw packet captures to determine remote host OS baseline before scanning.

ICMP Message Types Tested

Type 8: Echo Request | Type 0: Echo Reply | Type 3: Destination Unreachable | Type 11: Time Exceeded

Traceroute relies on ICMP Type 11 (Time Exceeded) when packet TTL decrements to 0.

2. Windows & Active Directory Internals

Active Directory

Active Directory FSMO Roles

Correct Answer: Total 5 Roles (2 Forest-Wide, 3 Domain-Wide)

Forest-Wide: Schema Master, Domain Naming Master.
Domain-Wide: PDC Emulator, RID Master, Infrastructure Master.
Query Command: `netdom query fsmo`

Domain Controller Discovery Commands

Native: nltest /dsgetdc:domain.local | DNS SRV: nslookup -type=srv _ldap._tcp.dc._msdcs.domain.local

Both tools are standard CPSA answers for querying DCs without full administrative privileges.

Critical Windows File Paths

SAM: C:\Windows\System32\config\SAM | NTDS.dit: C:\Windows\NTDS\ntds.dit

SAM stores local workstation hashes. NTDS.dit stores the complete Active Directory domain database.

Registry Hives Required to Extract Password Hashes

To dump SAM hashes, you must pair the SAM file with the SYSTEM hive.

The `SYSTEM` hive contains the Syskey (bootkey) required to decrypt the password hashes inside the SAM database.

Master Browser String & Enumeration Tool

String: ..__MSBROWSE__.. (Suffix <1D>) | Tool: nbtstat

Running `nbtstat -a <IP>` enumerates the NetBIOS name table and verifies if the target holds the Master Browser election.

3. Linux, Unix & Legacy Services

Linux / Unix

Berkeley R-Services Trusted Host Files

System-Wide: /etc/hosts.equiv | User-Level: ~/.rhosts (User Home Directory)

`hosts.equiv` grants system-wide passwordless access (cannot grant root).
`~/.rhosts` grants user-specific passwordless access (in `/root/.rhosts`, it allows passwordless root login).
Exam Trap: `/etc/hosts.allow` and `/etc/hosts.deny` belong to **TCP Wrappers**, not R-services.

NFS root_squash Mechanism

Correct Answer: Maps remote UID 0 (root) to the unprivileged account nobody.

Prevents a client with local root access from creating SUID binaries or accessing root-owned assets on the remote NFS export.

Octal Umask Directory & File Permissions

Base Directory: 777 | Base File: 666 | Effective = Base - umask

If umask is `022`: Directory is `755` (`rwxr-xr-x`), File is `644` (`rw-r--r--`).
If umask is `027`: Directory is `750` (`rwxr-x---`).

Unauthenticated (Open) X11 Server (xhost +)

Correct Answer: Attackers can log keystrokes, capture screenshots, and inject commands.

TCP port 6000 left open without authentication allows direct sniffing of user X11 input and display captures.

4. Cryptography, Hashing & Identity

Cryptography

SSH Banner Decoding: SSH-1.99-OpenSSH_3.9p1

Correct Answer: SSH server that supports both SSHv1 and SSHv2.

Vulnerable to MitM protocol downgrade attacks. SSHv1 uses broken CRC-32 integrity checks and lacks Perfect Forward Secrecy (PFS).
Note: SSHv3 does not exist.

Cisco Type 7 Passwords

Correct Answer: Weak, reversible XOR cipher with a fixed static key.

Type 7 is completely insecure and can be instantly reversed back to cleartext.

Linux /etc/shadow Hash Prefix Identifiers

1 = Salted MD5 | $2a$/$2y$ = Blowfish (bcrypt) | 5 = SHA-256 | 6 = SHA-512

Seeing `$1$3923923...` indicates obsolete, easily crackable MD5-crypt hashes.

Total Generations of WPA

Correct Answer: Exactly 3 Versions (WPA, WPA2, WPA3).

WPA (TKIP/RC4), WPA2 (CCMP/AES-802.11i), WPA3 (SAE Dragonfly Handshake).

5. Web Applications, Databases & Injection Attacks

Web & DB

LDAP Injection Testing Meta-Characters

Special Characters: * (wildcard), ( ), |, &, !, =

These characters alter the underlying boolean logic and filter delimiters in directory service queries.

Exposed Database 'sa' Account on the Public Internet

Violated Principles: Defense in Depth & Principle of Least Privilege

Databases should never be exposed externally (violates layered security/defense in depth), and applications should not use administrative `sa` accounts.

Apache Chunked Encoding Vulnerability

Vulnerability Type: Integer / Buffer Overflow leading to Remote Code Execution (CVE-2002-0392).

Malformed HTTP Transfer-Encoding chunk sizes allowed attackers to overwrite process memory.

3-Tier Web Application Architecture Role

Application Tier: Handles business logic, rule processing, and workflow management.

Presentation Tier handles user UI/HTML; Data Tier handles database queries and storage.

Invalid XSS Syntax & SQLi Tautologies

Invalid XSS: alert "abc" (Syntax Error) | Valid SQLi Bypasses: All tautologies evaluate to TRUE.

Valid XSS requires execution calls: `alert('abc')` or `alert`1`` .
SQLi bypass payloads: `' or 1=1;--` , `' or 2>1;--` , and `' or 'a'='a` are all valid.

Database Artifacts & Default Credentials

xp_cmdshell: MSSQL | Oracle Defaults: SYSTEM:MANAGER, SYS:CHANGE_ON_INSTALL, SCOTT:TIGER

`xp_cmdshell` spawns a Windows command shell with the rights of the SQL service account.

Cookie Encryption vs Secure Flag

Encrypted Content: Application-Layer Encryption | Secure Flag: Enforces HTTPS Transit Only

The `Secure` flag does not encrypt the cookie string; it only prevents transmission over unencrypted HTTP.

6. Subnetting & Network Architecture

Subnetting

Subnetting Master Formulas

Host Bits: h = 32 - CIDR | Total IPs: 2^h | Usable Hosts: 2^h - 2 | Magic Number: 256 - Subnet Octet

Subnets Created = `2^(Borrowed Bits)` .
Cisco Wildcard Mask = `255.255.255.255 - Subnet Mask` .

Usable Hosts in a /22 Subnet (192.x.x.x /22)

Correct Answer: 1022 Usable Hosts

Host bits: 32 - 22 = 10 bits.
Total IPs = 2^10 = 1024 total addresses.
Usable hosts = 1024 - 2 (Network ID & Broadcast) = **1022 usable hosts**.

The RFC 1918 Definition Trap: 10.0.0.0/16

Correct Answer: 10.0.0.0/16 does NOT correspond to an RFC 1918 reserved address range.

The strict RFC 1918 standard defines only: `10.0.0.0/8` , `172.16.0.0/12` , and `192.168.0.0/16` .
While `10.0.0.0/16` is a private subnet, it does not define the official RFC 1918 master boundary.

Account Lockout Policy Trade-Off

Vulnerability: Denial of Service (DoS) against legitimate domain users.

Strict lockout thresholds allow unauthenticated attackers to intentionally lock corporate and administrator accounts.